

SimpleRisk Release Notes

Version: 20260709-001

If you are not currently running SimpleRisk, please download the application and follow the installation instructions for your preferred method.

If you are running a previous release, navigate to **Configure** → **Register & Upgrade** and click **Upgrade the Application**. This process upgrades both the application and the database to the latest release.

Security Issues

- Strengthened protection against forged cross-site actions across the application.
- Replaced the external database-backup command with a safer, self-contained backup process.
- Required authenticated POST requests for state-changing actions so they cannot be triggered by a simple link.
- Hardened output encoding of chart configuration values.
- Hardened encoding of redirect destinations.
- Hardened output encoding of playbook content.
- Tightened permission enforcement on tag-lookup requests.
- Hardened output encoding of the governance framework description.
- The management API key is now stored as a secure hash rather than as recoverable text.
- Enforced view-permission checks on compliance file downloads.
- Tightened permission enforcement on marking projects incomplete.
- Tightened permission enforcement on high-privilege fields in the risk-update API.
- Tightened permission enforcement on custom risk-score updates.
- Hardened encoding of administrator-configured colors used in reports and dashboards.
- Required an authenticated POST request for the risk reopen action.
- Restricted the Workflows HTTP Request action to an administrator-managed allow-list of approved destinations.
- Enforced per-module permission checks on internal data-table requests.
- Enforced team-separation checks on single-asset API lookups.
- Required the management API key to be sent as a request header rather than in the URL or form body.
- Enforced module permission checks on risk-report data-table requests.
- Scoped the user-manager API lookup behind a permission check.
- Tightened permission enforcement on risk tooltip requests.
- Tightened permission enforcement on risk review submissions.
- Validated the configured database-backup command path to prevent unsafe execution.

- Enforced permission checks across the remaining risk-management reporting requests.
- Restricted contributing-risks data-table requests to administrators.
- Tightened permission enforcement on review-date corrections.
- Tightened permission enforcement on incident-management configuration changes.
- Tightened permission enforcement on vulnerability-management updates.
- Enforced permission checks on incident-management report views.
- Enforced asset-access checks on the asset verify, discard, and delete actions.
- Scoped questionnaire answer pre-population to the same respondent to prevent cross-respondent disclosure.
- Hardened output encoding of the Jira link shown in the risk detail view.
- Tightened permission enforcement on assessment tag enumeration.
- Hardened output encoding in the risk filtering form action.
- Hardened output encoding of control names in the asset mapped-controls view.
- Hardened output encoding of chart axis titles and restricted chart selection options to an approved allow-list.
- Tightened permission enforcement on questionnaire result approval actions.
- Hardened spreadsheet exports of the Dynamic Risk Report against untrusted content that could be interpreted as a spreadsheet formula.
- Enforced a column-name allow-list and hardened encoding for custom display-settings columns.
- Restricted AI provider connections to an administrator-managed allow-list of approved destinations.
- Hardened workflow-driven updates to rich-text fields against stored malicious content.
- Hardened rich-text fields on controls, exceptions, tests, risks, mitigations, and reviews against stored malicious content.
- Required authenticated POST requests for the Upgrade Extra backup and upgrade actions.

New Functionality

- Custom language files can now override only the strings you want and fall back to a base language for everything else, so they no longer need to carry the full string list on every upgrade.

Performance / Availability

- Faster activation of the Custom Authentication Extra on new installs.
- Faster activation of the Import-Export Extra on new installs.
- Faster activation of the Encrypted Database Extra on new installs.
- Faster activation of the Artificial Intelligence Extra on new installs.
- Faster activation of the Vulnerability Management Extra on new installs.
- Faster activation of the Team-Based Separation Extra on new installs.

Aesthetics / User-Interface

- The Risk Assessment scheduling frequency now shows a clear disabled indicator instead of an ambiguous "0 days".
- Added confirmation feedback when clicking Save Draft on a questionnaire that has no unsaved changes.

SimpleRisk Extra Development

- Added a Reopen action for rejected questionnaire results in the Risk Assessment Extra.
- The Risk Assessment Extra now allows editing scheduling and notification fields after a questionnaire has been sent.
- Added a Risk Assessment Extra API endpoint that returns a respondent's submitted questionnaire answers as structured JSON.
- Fixed SAML SSO asset and module URLs not resolving correctly with the authentication Extra.

Bug Fix

- Fixed a fatal error when activating the Incident Management Extra after a permission key had been renamed.
- Fixed controls without a framework not appearing on the Define Tests page.
- Fixed controls without a framework not appearing on the Initiate Audits page.
- Fixed audit filter inputs unintentionally triggering column sorting.
- Fixed the Framework Name filter missing an "Unassigned" option.
- Fixed a server error on the Document Program page when a stakeholder table was missing.
- Preserved existing values when deactivating the Encrypted Database Extra to prevent silent data loss.
- Fixed screens that display tags, such as the Dynamic Risk Report, failing to load on PHP 8.4.
- Fixed a sent questionnaire still showing an editable form and a Save & Send button in the Risk Assessment Extra despite being non-editable.
- Fixed a crash during CSV import on PHP 8.1 when the file had no enclosure character.
- Fixed Shift+Enter inserting a block break instead of a line break in rich-text editor fields.
- Fixed the bypass-pending-risks checkbox not saving correctly on the questionnaire edit form.
- Fixed questionnaire draft save silently failing while still showing a success message for logged-in users.
- Fixed unknown API v2 routes returning HTTP 200 instead of HTTP 404.
- Fixed questionnaire draft save silently dropping file uploads.
- Fixed the questionnaire Draft button freezing the page when nothing had changed.
- Fixed removing a file from the questionnaire upload queue not being detected as a draft change.
- Fixed removed files reappearing after reloading the questionnaire fill page.
- Fixed a server error from the risk-average report API when given a non-numeric risk id.
- Fixed a server error from the send-questionnaire API when the id was missing.

- Fixed incomplete-questionnaire reminder emails firing indefinitely with no expiry once the response token had expired.
- Permission changes now take effect in the current session without requiring users to log out and back in.
- Fixed literal HTML entities such as appearing in the Dynamic Risk Report XLS export and other report and audit-trail exports.
- Fixed a spurious "could not decrypt" message on the Dynamic Risk Report for risks with empty fields.
- Fixed a fatal error that could occur when a newer Extra ran against an older core release.
- Fixed background document-processing issues that could cause excessive database growth, processing delays, and out-of-memory failures on large attachments, and ensured every file in a multi-file document is processed.
- Corrected the wording of the Encrypted Database activation error messages so they translate correctly across all supported languages.
- Fixed the Install buttons for the Workflows and Artificial Intelligence Extras on the registration page, which previously did nothing when clicked.